Разведка по открытым источникам



Статистика атак. OSINT. Защита личных данных. Право и этика

Содержание занятия

1 **Основы ИБ и статистика атак** три аспекта ИБ, человеческий фактор, утечки данных

2 **OSINT: определение и виды** кто использует, характеристики источников

3 **Практика OSINT** инструменты, кейсы, браузер

4 **Защита** цифровой след, пароли и 2FA, покупки, ИИ-сервисы, взлом аккаунта

5 **Право, этика и вопросы** где граница законного сбора данных, задания

БЛОК 1

Основы ИБ и статистика атак

Три аспекта ИБ, человеческий фактор, утечки данных

Безопасность объекта информатизации



ТЗИ (СЗИ)



Человеческий фактор

Человеческий фактор в цифрах

60%

успешных атак на организации в России используют социальную инженерию (было 49%)

83%

финансово мотивированных атак строятся на социальной инженерии — чаще всего фишинговые письма

86%

атак с социнженерией приходят по электронной почте (мир, 2025)

+30–35%

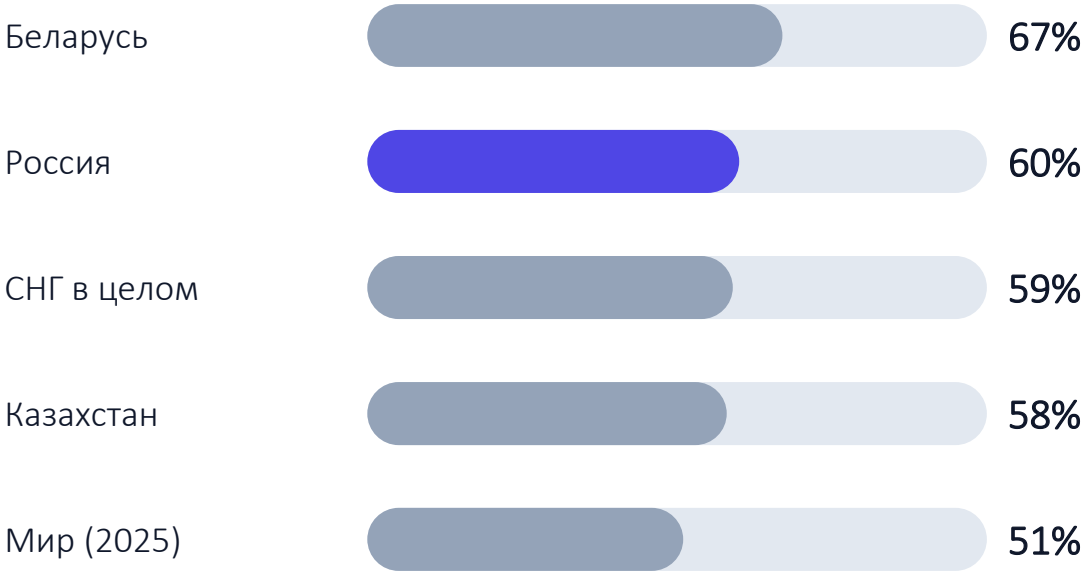
прогноз роста числа успешных кибератак на российские организации в 2026 г.

Периметровая защита без работы с людьми не спасает: сотрудники и обычные пользователи остаются главным входом для атакующих.

Источники: Positive Technologies — CODE RED 2026 (июль 2024 – сент. 2025), «Тренды атак в 2026 году», прогноз PT на 2026 г.

Кого и как атакуют

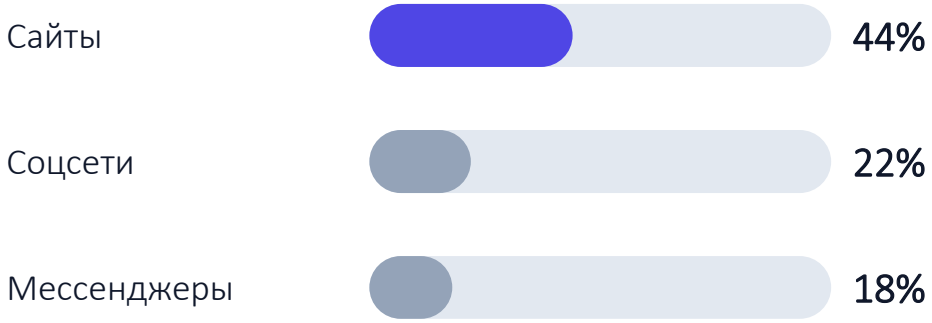
Доля успешных атак на организации с использованием социальной инженерии



88%

атак на частных лиц используют социальную инженерию (IV кв. 2024)

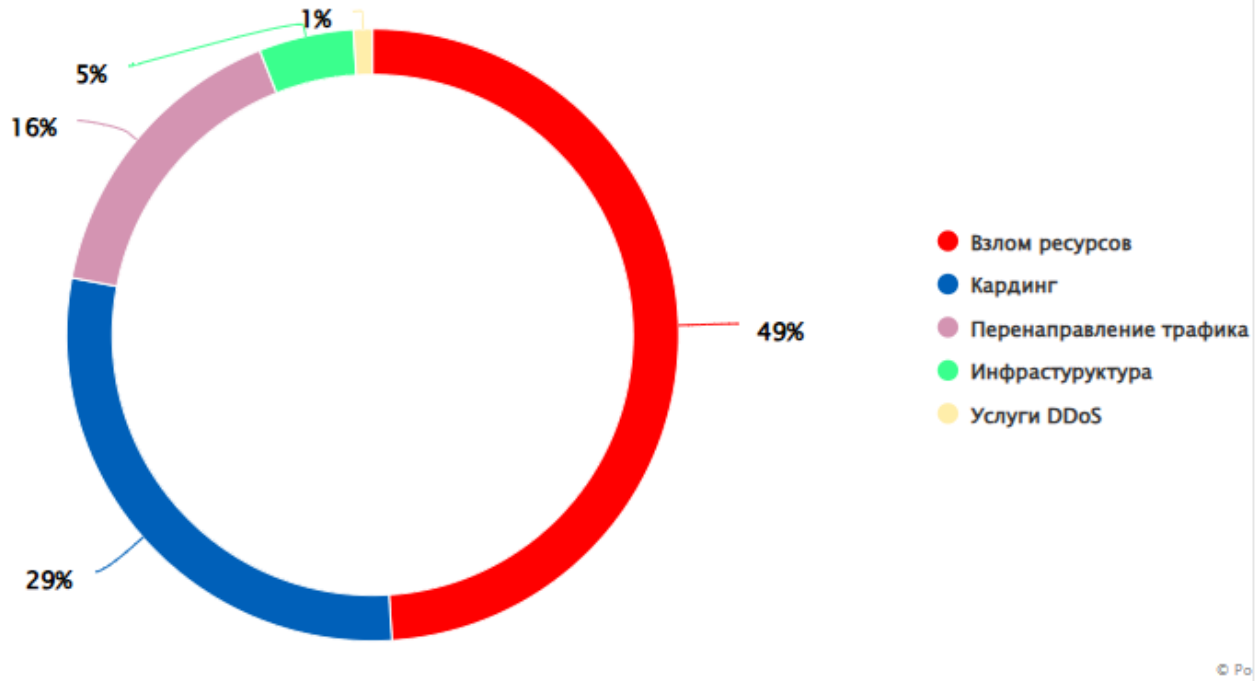
Каналы атак на частных лиц: чаще всего сайты, затем соцсети и мессенджеры



Источники: Positive Technologies — «Актуальные киберугрозы для организаций в СНГ: H2 2024 – Q3 2025», «Тренды атак в 2026 году»; частные лица — IV кв. 2024 (по CNews).

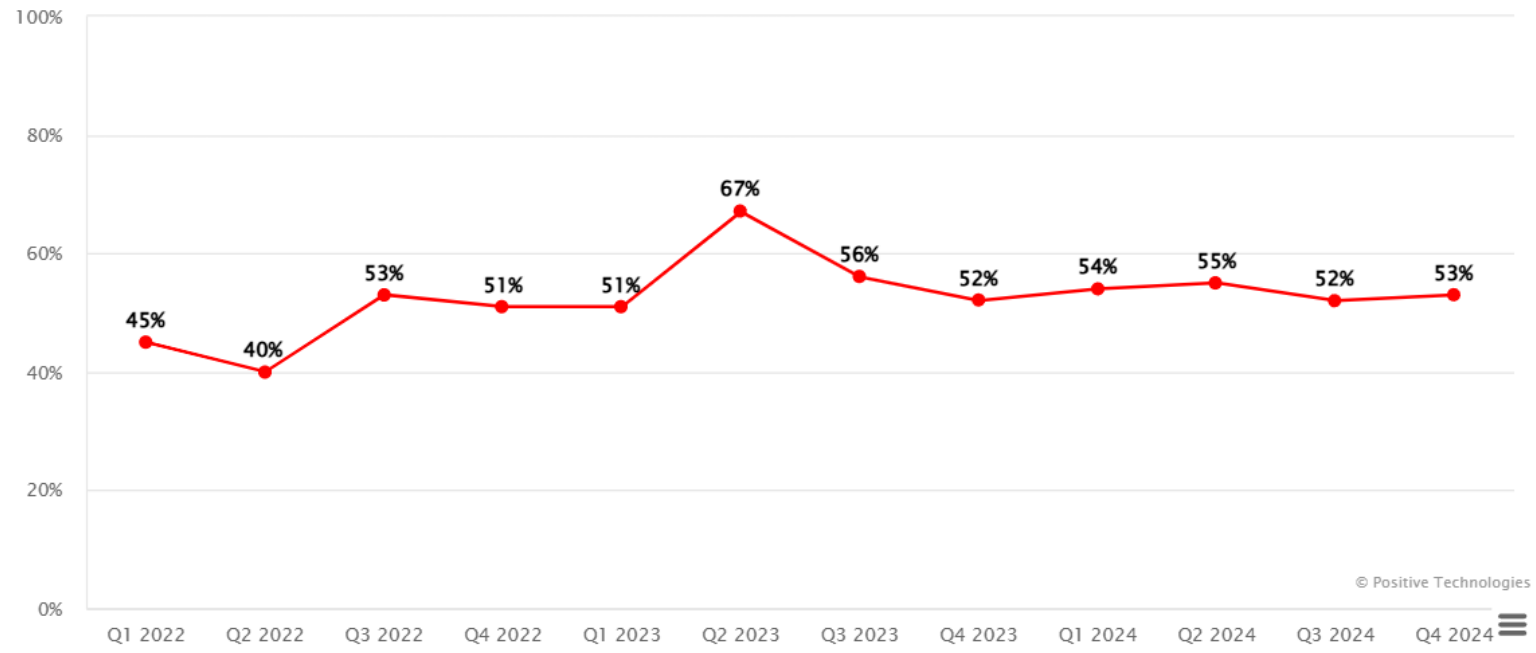
Киберпреступные услуги

Рисунок 51. Сообщения на тему киберпреступных услуг



Статистика утечек данных

Рисунок 1. Динамика доли успешных атак на организации, закончившихся утечками данных



Утечки по странам

Продажа

28% ↘

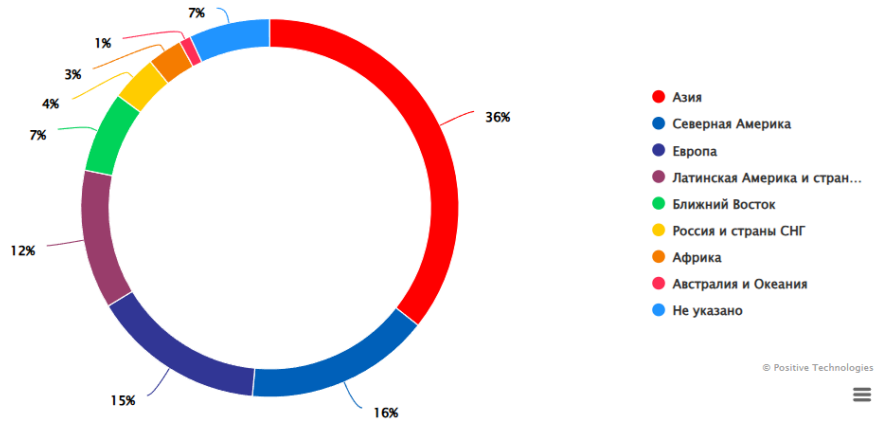
объявлений, связанных с утечками

Средняя* цена, указанная в объявлениях о продаже данных

Данные платежных карт	2500 $	Внутренние файлы	1500 $
Медицинские данные	2000 $	Учетные данные	1150 $
Исходный код	2000 $	Персональные данные	835 $

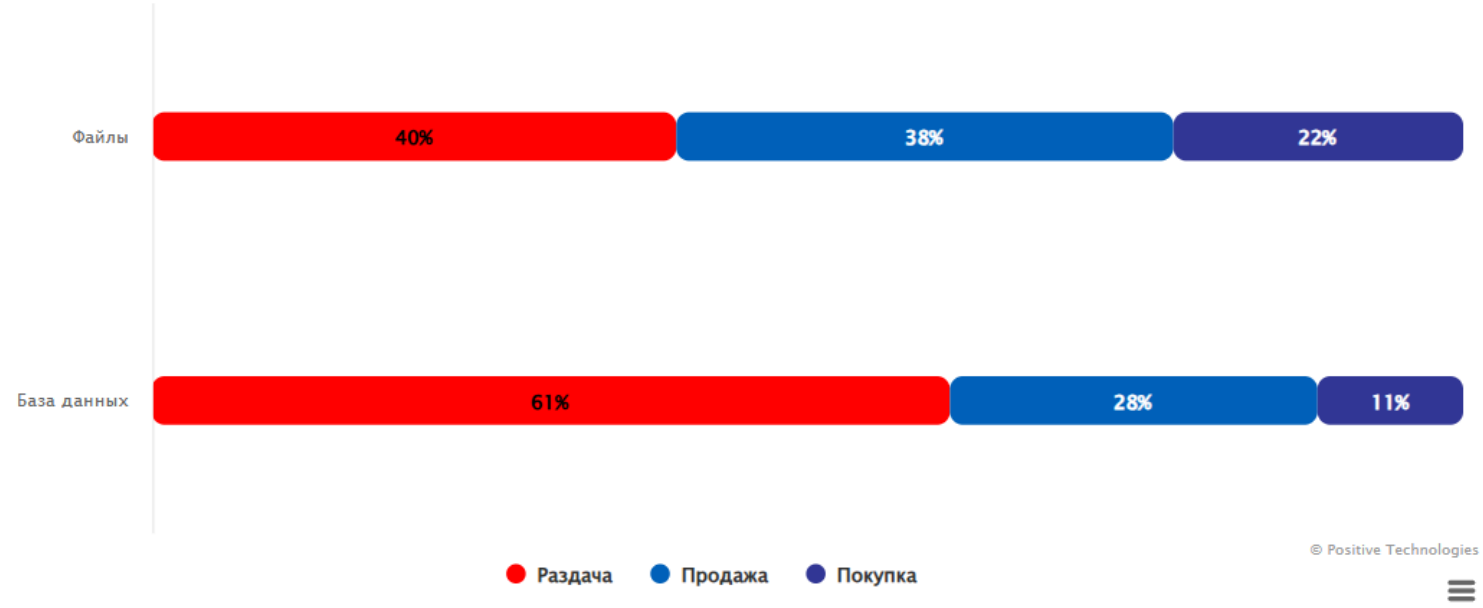
* В качестве среднего приведены медианные значения

Рисунок 23. Распределение объявлений по регионам



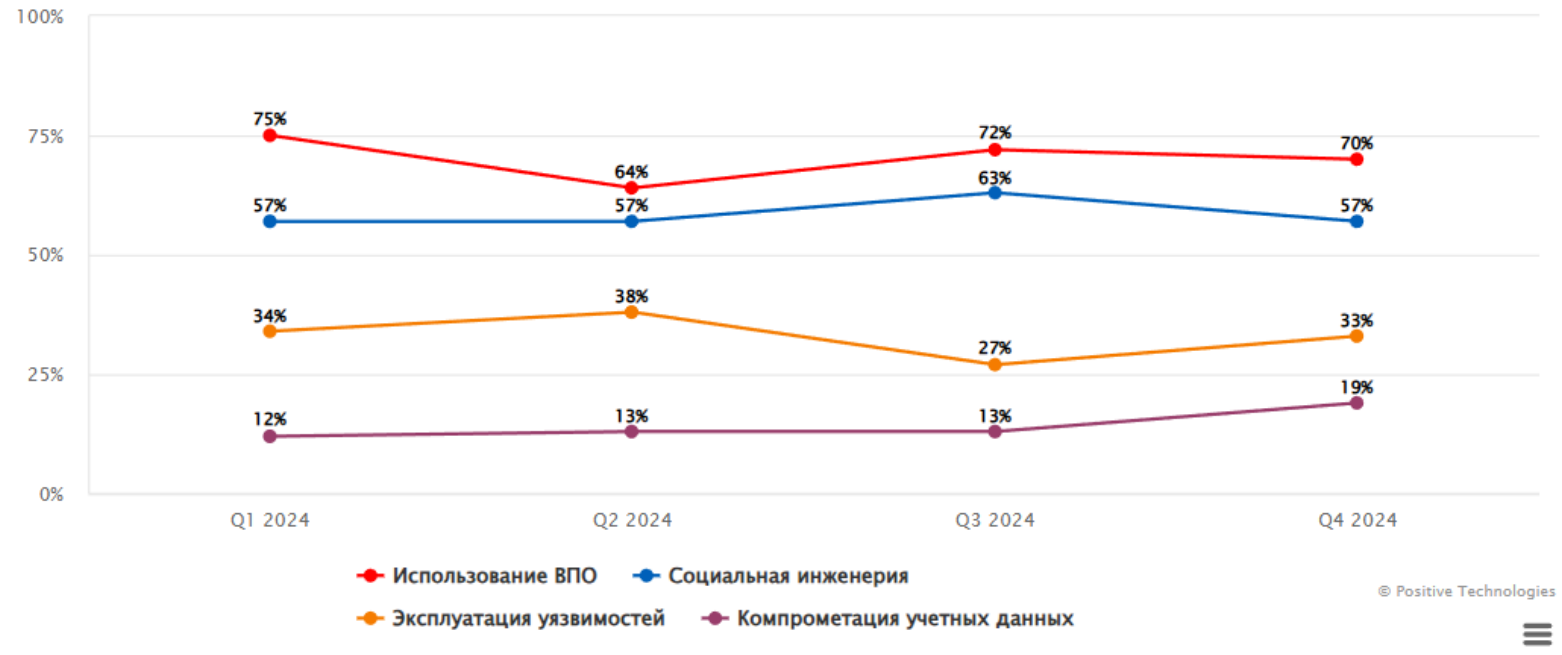
Утечки по отраслям

Рисунок 16. Распределение объявлений по типам в зависимости от категории данных



Методы организации утечек

Рисунок 39. Методы, использованные в успешных атаках на организации, последствием которых стали утечки



Реальный инцидент: атака на Asahi, 2025

Суть атаки

В конце сентября 2025 года группировка Qilin с помощью информации, полученной из открытых источников, проникли в корпоративную сеть через уязвимое сетевое оборудование на одном из региональных объектов группы. Оставаясь незамеченными в течение 10 дней, они внедрили программу-вымогатель, зашифровали критически важные данные и похитили конфиденциальную информацию (включая финансовые документы и персональные данные сотрудников, скриншоты которой появились в даркнете).

Данные

Asaki отказалась платить выкуп, в результате чего были опубликованы 27 ГБ похищенных данных. Это превратило слитую информацию в легальную базу для целевого фишинга и дальнейшего OSINT-анализа со стороны других преступников

Финансовый удар - итоги

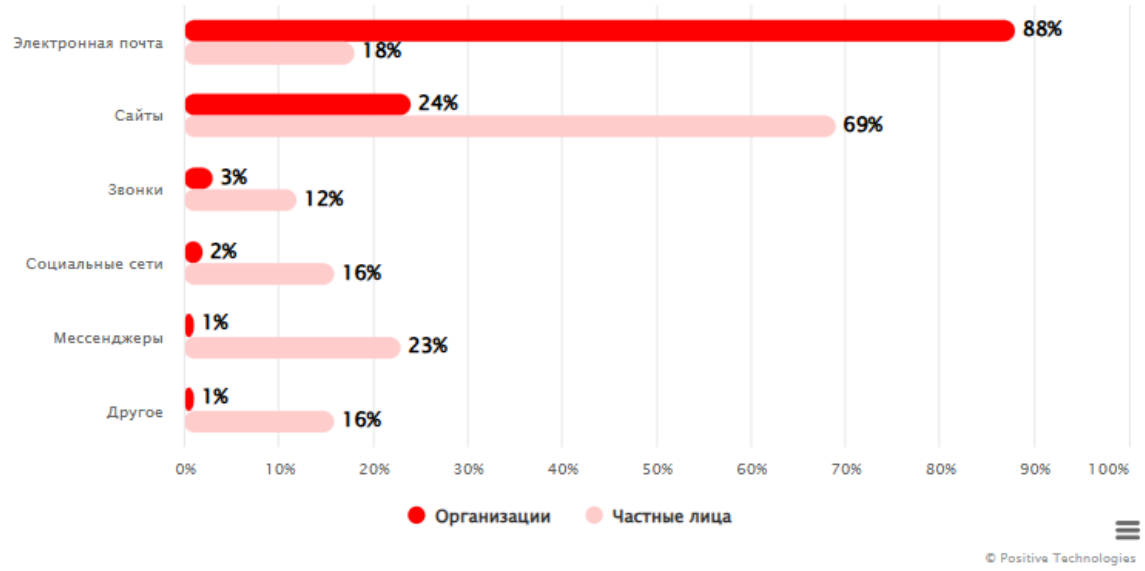
Согласно отчетности, опубликованной в июле 2026 года, кибератака стала главной причиной серьезного проседания показателей Asahi Group Holdings:

- Чистая прибыль упала на 36,7% по сравнению с предыдущим годом и составила 121,5 млрд иен (около $748 млн).
- Операционная прибыль от основной деятельности сократилась на 7,8% — до 262,9 млрд иен.
- Годовая выручка снизилась на 1,5% — до 2,89 трлн иен.

После инцидента компания перешла на концепцию непрерывного мониторинга угроз, полностью изолировала критически важные промышленные сети от офисных, ужесточила контроль внешних подключений и ввела новые стратегии резервного копирования.

Каналы социальной инженерии

Рисунок 3. Каналы социальной инженерии (доля успешных атак, H1 2025)



БЛОК 2

OSINT: определение и виды

Что это, кто использует, характеристики информации и источников

Глоссарий

OSINT разведка по открытым источникам

Социальная инженерия манипуляция человеком ради доступа или данных

Фишинг поддельные письма и сайты, которые выманивают данные

Доксинг сбор и публикация личных данных человека без его согласия

Деанонимизация установление личности по косвенным признакам

Утечка / кража данных случайное раскрытие против умышленного хищения

2FA двухфакторная аутентификация: второй шаг входа

ВПО вредоносное ПО, включая шифровальщики

OSINT

- (Open source intelligence) разведка по открытым источникам, которая заключается в поиске, выборе, сборе и анализе разведывательной информации из общедоступных источников.

Его применяют:

- Государственные органы
- Международные организации
- Гуманитарные организации
- Правоохранительные органы
- Бизнес-корпорации
- Заинтересованные лица.



Виды OSINT

Пассивный

заключается в получении данных о цели исключительно через публичные открытые источники.

Полупассивный

пытается имитировать типичный интернет-трафик, что позволяет производить разведку скрытно, не привлекая внимания неординарным поведением.

Активный

не подразумевает сокрытия факта разведки от цели сбора, поскольку требует прямого взаимодействия с ней. Эти действия едва ли удастся замаскировать под обычные.
К данному методу разведки также относятся атаки, базирующиеся на социальной инженерии.

Плюсы и минусы OSINT

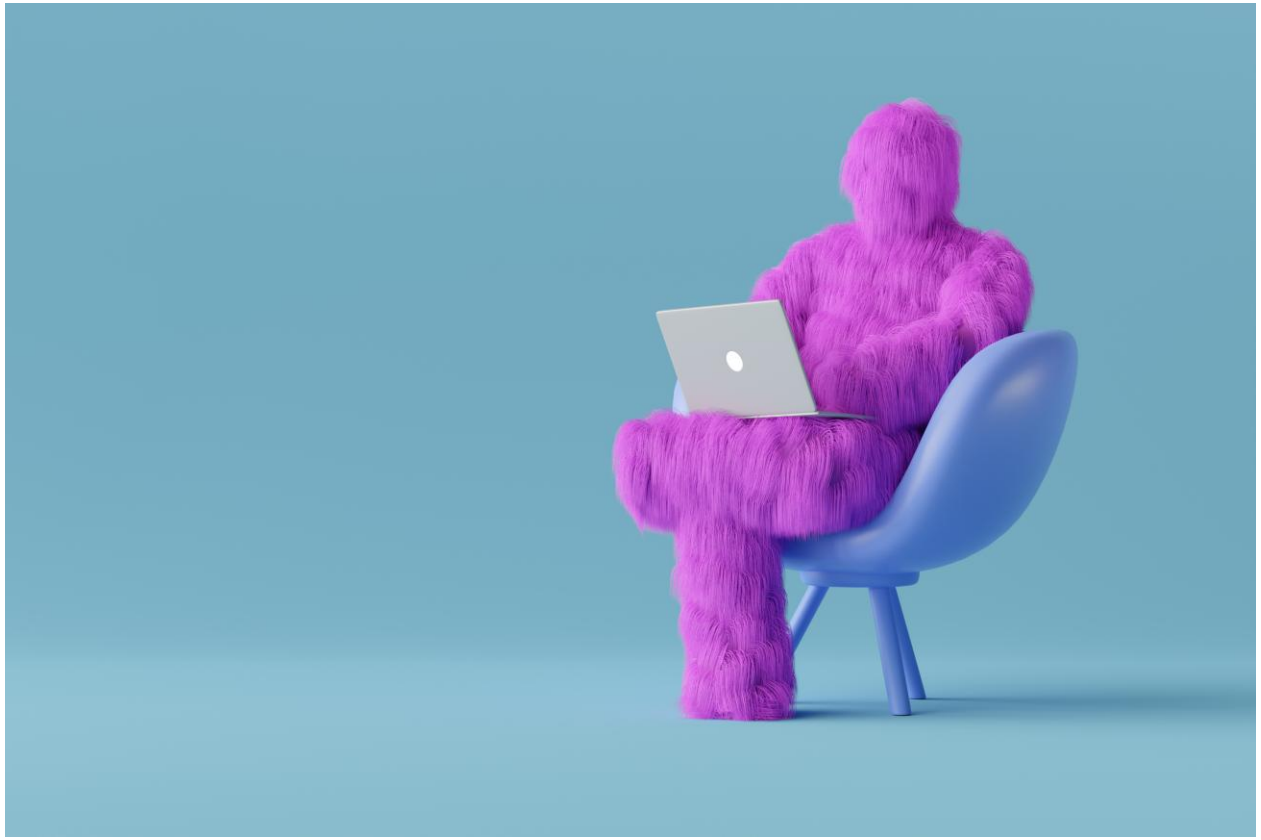
+ Минимальные риски
+ Экономическая эффективность
+ Удобство доступа
+ Правовые вопросы
+ Помощь правоохранительным и контрольным органам в финансовой сфере
+ Борьба с фейками в Интернете

− Огромный объем данных
− Надежность источников
− Трудоёмкость и жёсткие требования к квалификации аналитика, проводящего OSINT

Эффективные методы сбора OSINT-информации

Источники данных

- публикации в СМИ, научных изданиях, доклады на конференциях
- посты и комментарии в социальных сетях
- документы из открытых архивов, публичные данные из государственных информационных систем, судебная информация
- публичные коммерческие данные (выручка, прибыль, стоимость акций)
- данные о структуре и сотрудниках компаний с их сайтов и страниц в социальных сетях
- слитые базы



OSINT в жизни: где он приносит пользу

Проверка контрагентов сведения о компании, учредителях и судебных спорах из открытых реестров перед сделкой

Журналистика и фактчекинг поиск первоисточника фото и видео, геолокация публикаций, разоблачение фейков

Поиск пропавших людей волонтёрские поисковые отряды проверяют публичные данные и публикации

Кибербезопасность поиск утечек данных компании, поддельных доменов и фишинговых страниц

Учёба и исследования поиск первоисточников, статистики и публикаций для курсовых и дипломов

Граница проходит там, где заканчивается законная задача: собирайте только то, что нужно для проверки, и только законными способами

Характеристики информации



Доронин А. Бизнес-разведка

Критерии оценки информации

1 Объективность – необъективность
объективная информация максимально очищена от мнений, оценок, суждений

2 Достоверность – недостоверность
достоверная информация отражает истинное положение дел

3 Полнота – неполнота
если информация полна, то ее достаточно для принятия правильного решения

4 Актуальность – неактуальность
ценность информации резко падает со временем

5 Ценность – бесполезность
информация полезна лишь по отношению к решаемым задачам

6 Понятность – непонятность
зависит от того, насколько доступным для получателя информации языком она выражена

Ющук Е. Конкурентная разведка

Классификация источников информации



Первичные

сведения, полученные непосредственно от участников событий либо впервые ставшие доступные благодаря поиску



Вторичные

структурированная информация, собранная для определенных целей, отличных от целей, которые стоят перед аналитиком в данный момент



Внутренние

аналитик может получить данные из документов организации, к которым имеет доступ, или от ее сотрудников



Внешние

сведения принадлежат другим организациям либо общедоступны (СМИ, библиотеки)



Открытые

общедоступны, публичны, не требуют конфиденциальности



Закрытые

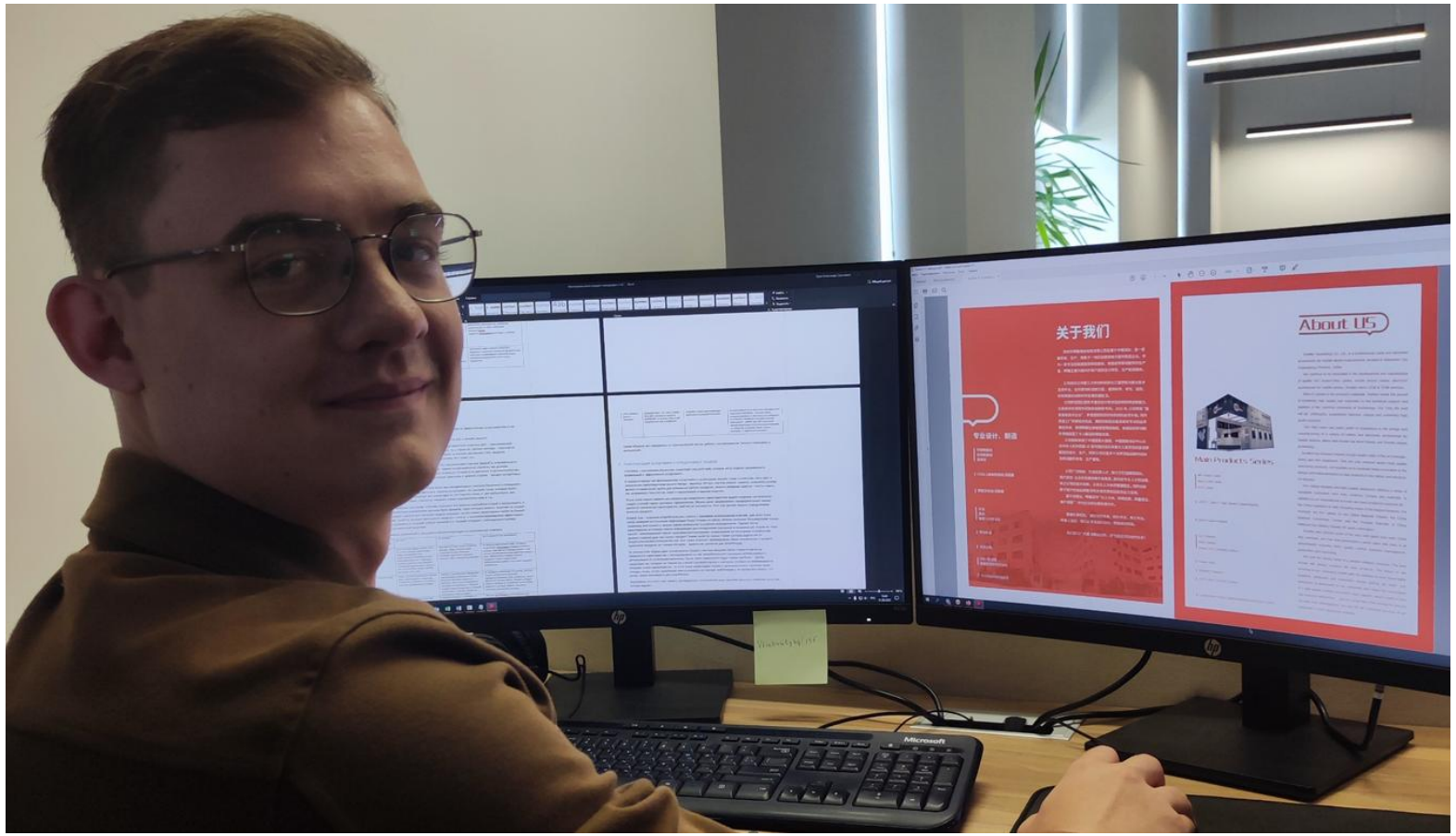
недоступны для всех желающих, использование часто незаконно

БЛОК 3

Практика OSINT

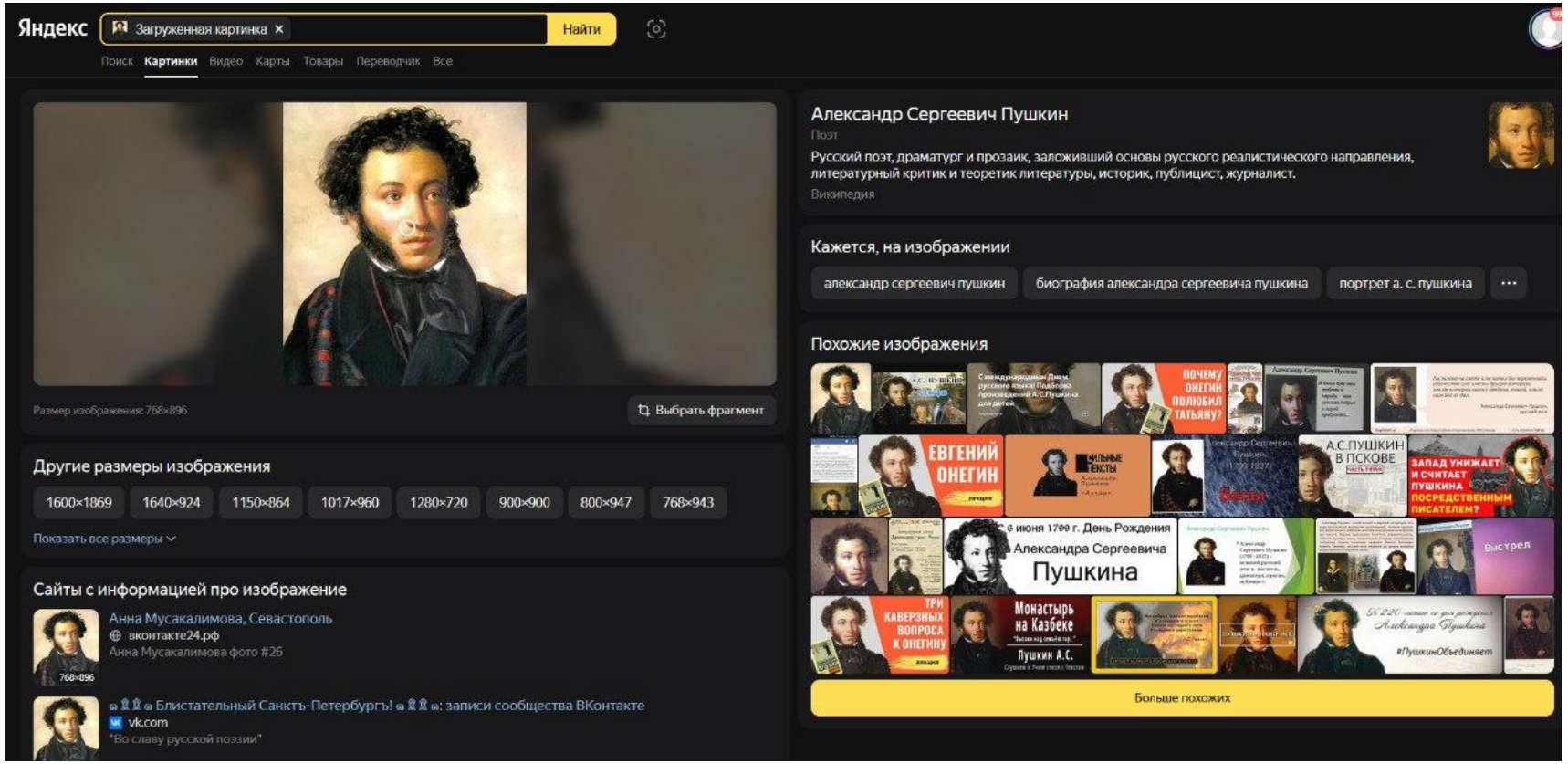
Инструменты, кейсы, работа с браузером

Взлом без кары по УК РФ*



*Вход в систему с данными, полученными в результате анализа все же является неправомерным доступом, ведущим к уголовной ответственности.

OSINT: Яндекс Картинки



Практический OSINT: Яндекс картинки

Яндекс картинки позволяют, используя фотографию объекта, найти ссылки или же подобные картинки. Это часто используется, когда нужно найти человека в другой соцсети.

OSINT: Google Dorks

Практический OSINT: Google Dorks

Операторы Google предоставляют сужать выдаваемую информацию поисковиком. Основные из них:

- site — искать по конкретному сайту;
- inurl — указать на то, что искомые слова должны быть частью адреса страницы / сайта;
- intitle — оператор поиска в заголовке самой страниц;
- filetype — поиск файлов конкретного типа по расширению.

Также при создании Дорка надо знать несколько важных операторов, которые задаются спецсимволами.

| — оператор OR он же вертикальный слеш (логическое или) указывает, что нужно отобразить результаты, содержащие хотя бы одно из слов, перечисленных в запросе.

«» — оператор кавычки указывает на поиск точного соответствия.

— — оператор минус используется для исключения из выдачи результатов с указанными после минуса словами.

* — оператор звездочка, или астериск используют в качестве маски и означает «что угодно».

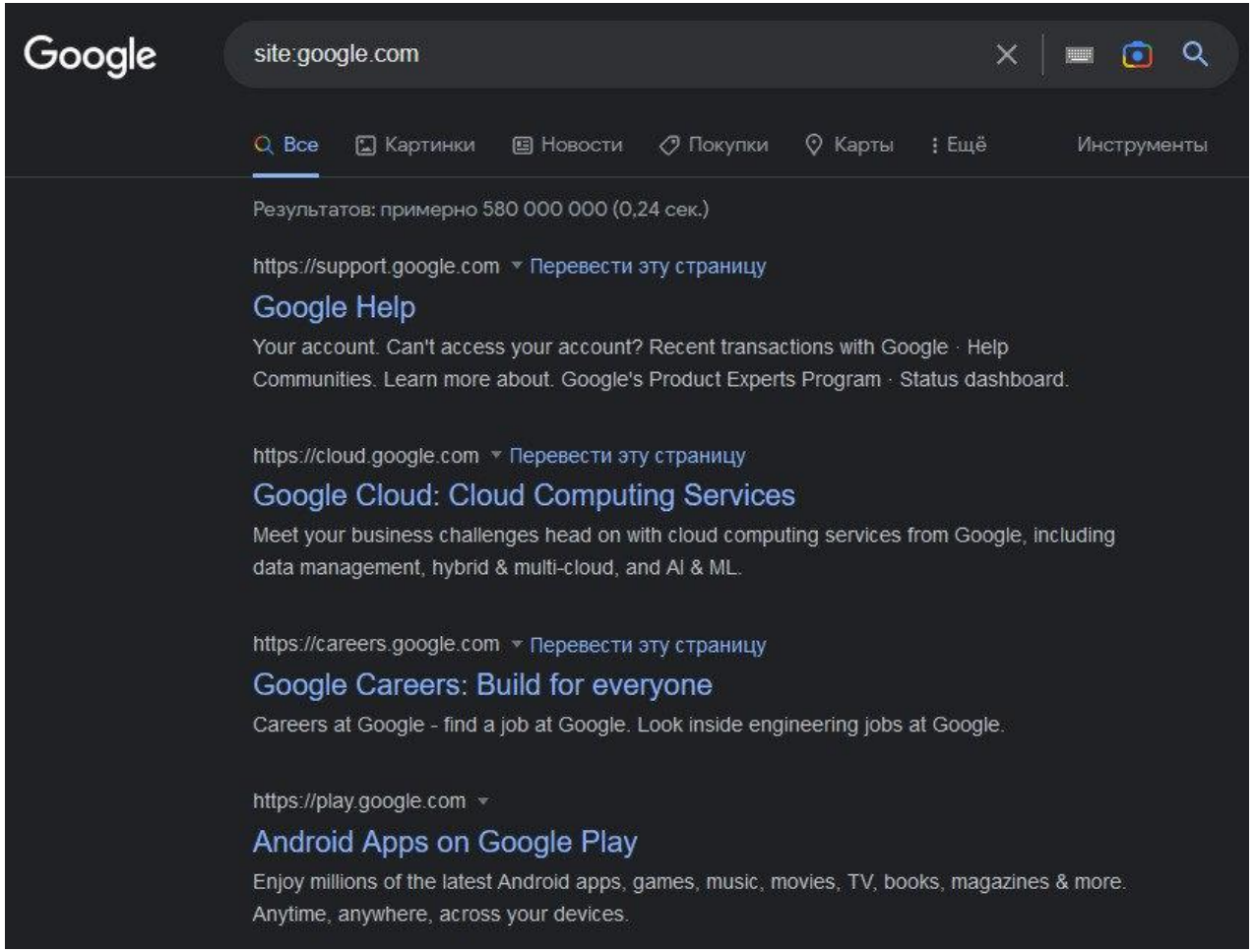
OSINT: Google Dorks, site:

Практический OSINT: Google Dorks

Google Dorks*

Поиск с помощью site

Как видим на скриншоте, поисковик выдал нам информацию, связанную с сайтом «google.com».



OSINT: Google Dorks, поиск по слову

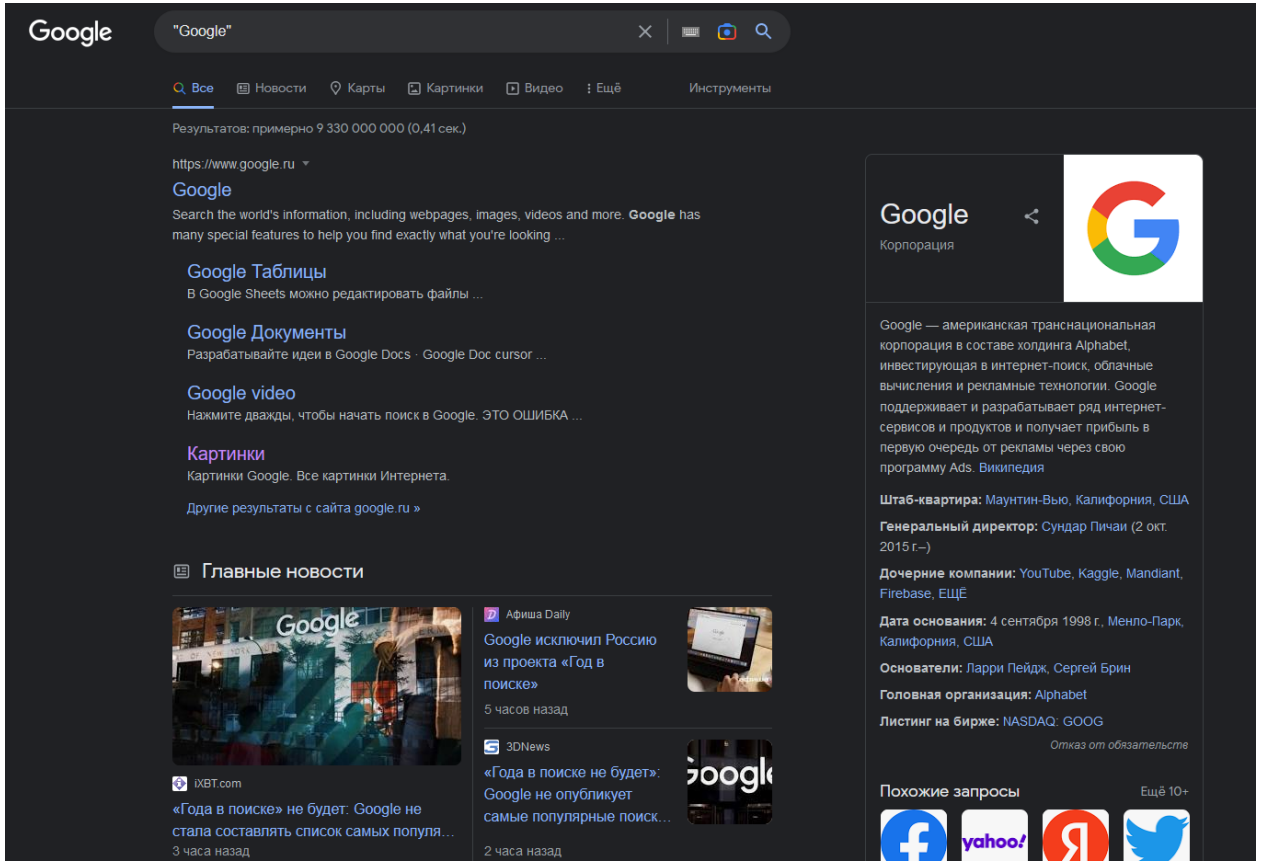
Практический OSINT: Google Dorks

Google Dorks

Поиск сайтов, где содержится определенное слово

На данный поисковый запрос, Google выдал нам сайты, где содержится слово «Google»

Данные запросы позволяют находить чувствительную информацию, как:
- Пароли
- Логи
- Открытые камеры
- И так далее…



OSINT: Shodan, IP-адрес

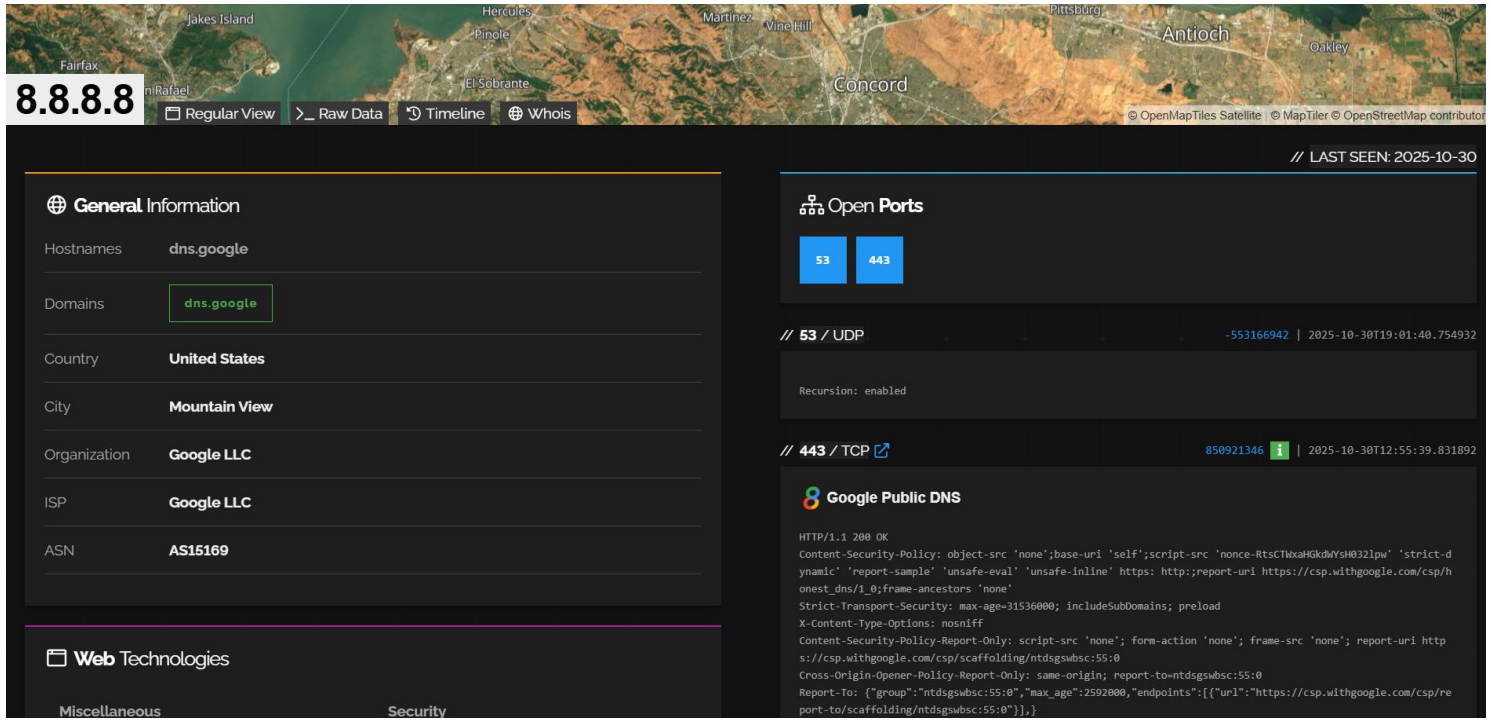
Shodan — это поисковая система для поиска устройств, подключенных к Интернету, таких как серверы, веб-камеры и маршрутизаторы, используя различные фильтры. Она действует как поисковая система по сервисным баннерам — метаданным, которые серверы отправляют клиентам при подключении, и позволяет получать информацию об устройствах, находящихся в сети.

Что может собирать Shodan:

Название и тип устройства

Имя пользователя и пароли по умолчанию

Географическое положение



По IP адресу 8.8.8.8 (который принадлежит Google) мы нашли, что IP адрес действительно принадлежит Google. Описаны открытые порты, информация, получаемая с них и геолокация.

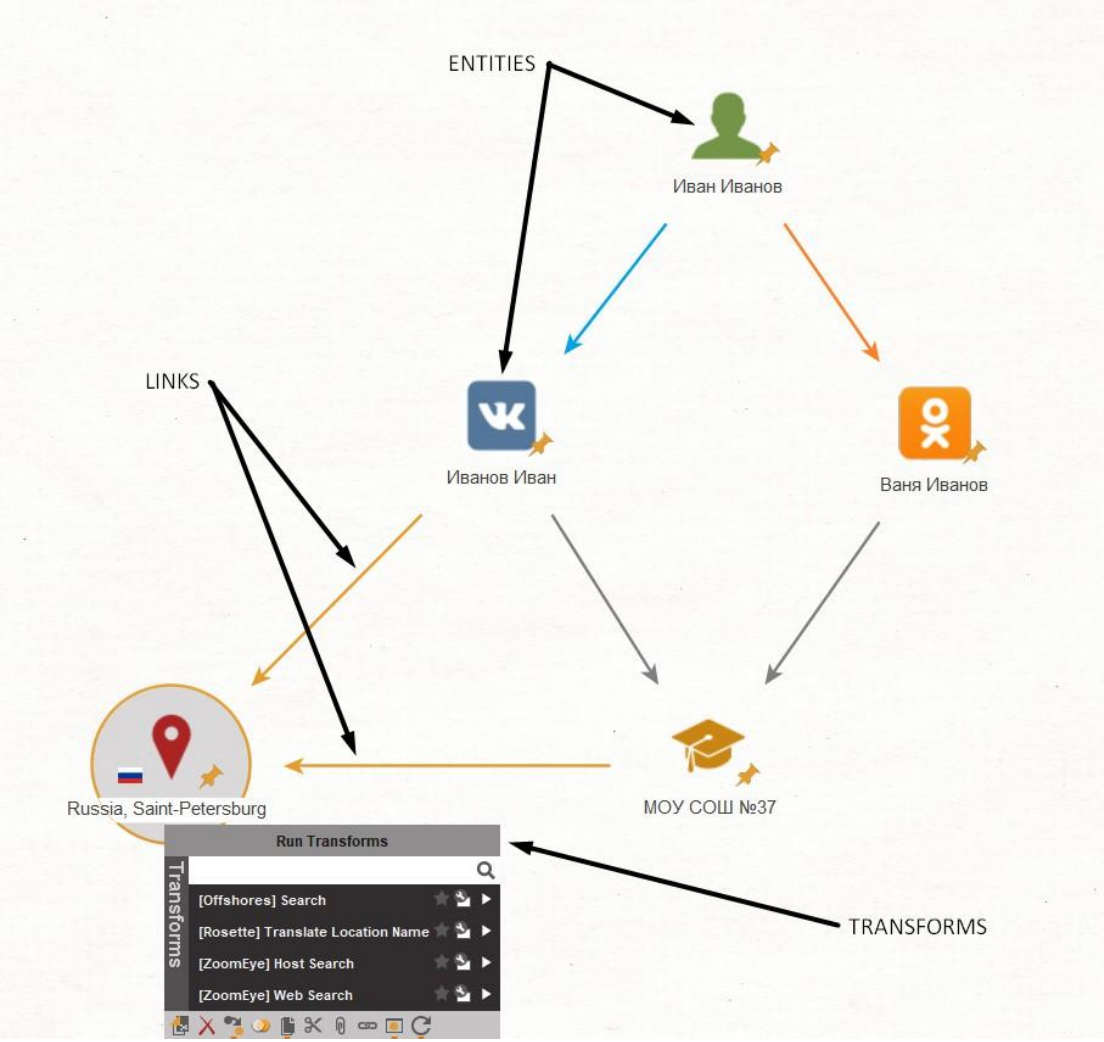
OSINT: Maltego

Практический OSINT: Maltego

Maltego позволяет искать информацию и формировать граф зависимостей.

Данное ПО можно представить как доску для детективов, где наглядно понятно: что из чего следует. Данный инструмент облегчает строить связи между объектами исследований.

Здесь построена связь информации об вымышленном персонаже Иване Иванове.

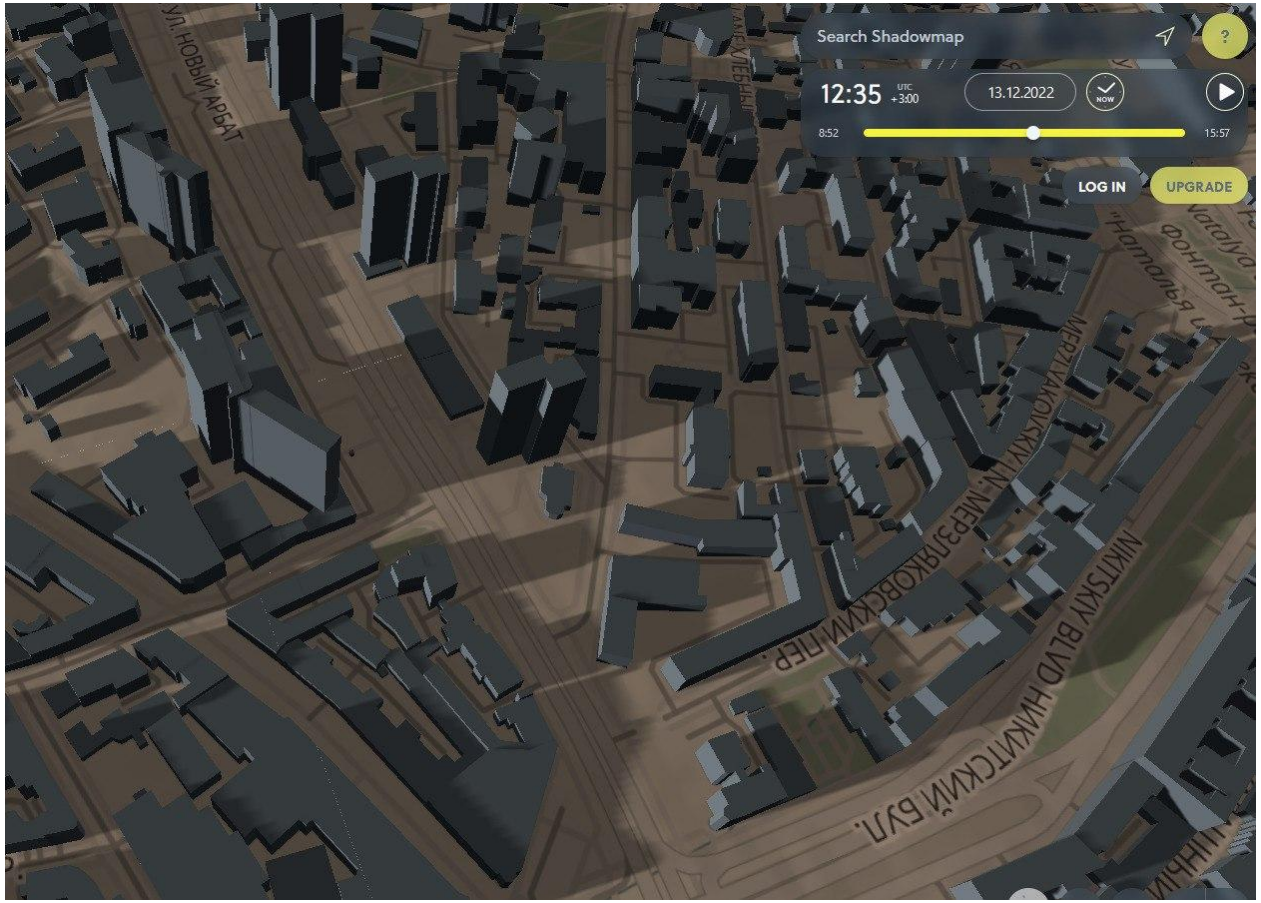


OSINT: ShadowMap

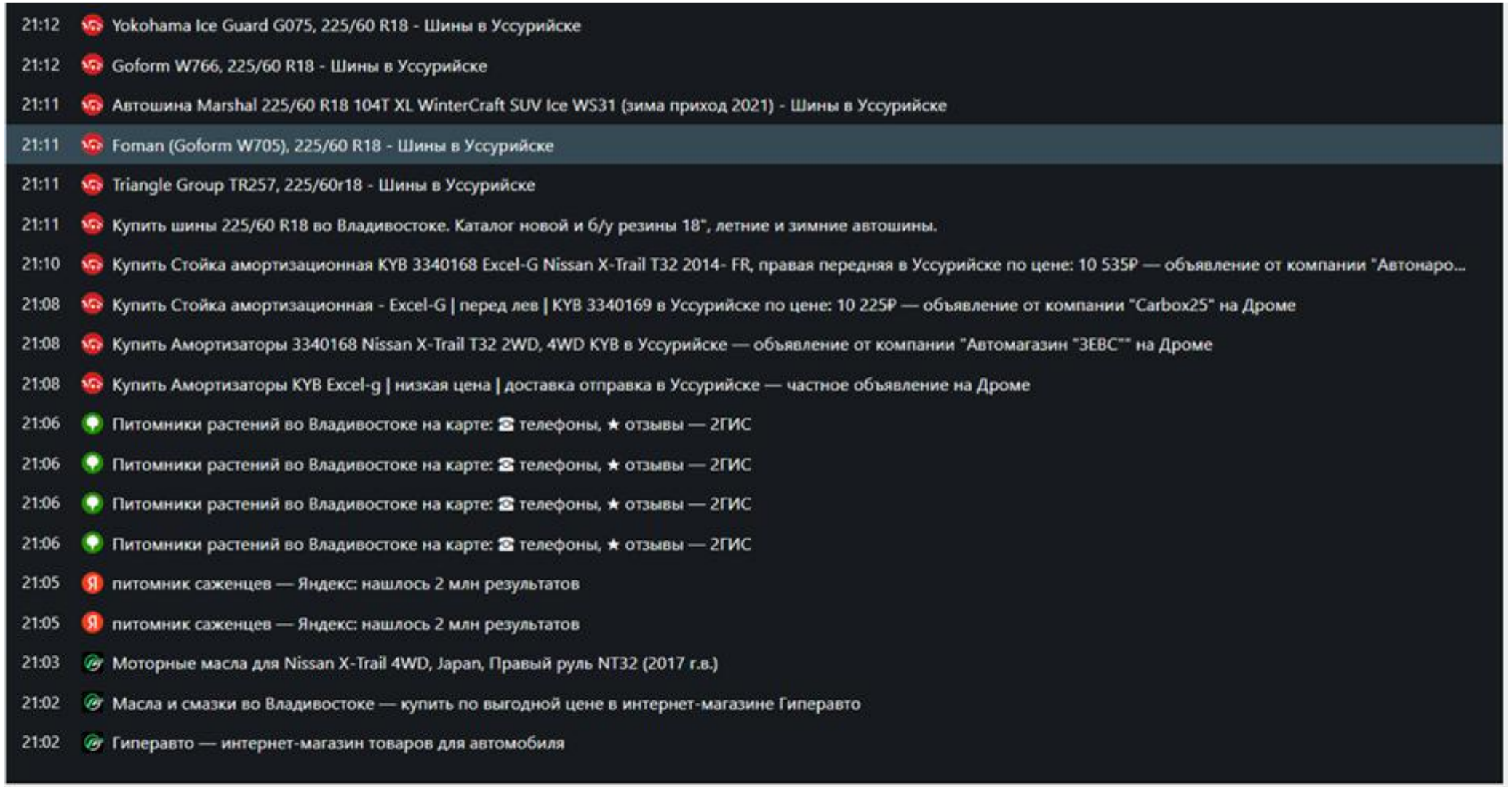
Практический OSINT: ShadowMap

Данный инструмент помогает определить положение солнца в любой момент времени.

Используя ShadowMap, разведчик способен по углу падения солнечных лучей определить точное место съёмки (при условии того, что примерный радиус геопозоции мы знаем)



Анализ истории браузера



Crowd-source OSINT

« Худший в истории фоторобот» помог поймать преступника

За неделю до ареста в полицейские участки округа был разослан нелепый и убогий фоторобот, который стал предметом насмешек среди полицейских и местных жителей, которые растиражировали его в интернете.

Однако в итоге именно благодаря этому рисунку и был пойман злоумышленник Гленн Ранделс, которого обвиняют в ограблении с отягчающими обстоятельствами, непристойном обнажении, взломе жилища, хулиганстве и уклонении от ареста.





Фото-подсказка от Google Street View

На одном из снимков, сделанных камерами сервиса Google Street View, полицейские опознали одного из самых разыскиваемых преступников – приговоренного к пожизненному заключению гангстера Джоаккино Гаммино. Вскоре мужчину задержали.

Выяснилось, что последние 20 лет Гаммино проживал в небольшом городе неподалеку от Мадрида, а местным жителям он был известен как Мануэль – владелец овощного магазина и шеф-повар ресторана.



Google и побег из тюрьмы



Выявление киберпреступников

В случае с Breach Forums исследователи могли отслеживать деятельность ключевых фигур, таких как "pompompurin" и "IntelBroker", используя комбинацию технической и социальной разведки.

Использовались методы форензики, отслеживания паттернов в общении и анализа взломанных систем.

OSIVE (Open Source Intelligence Visualization Engine) помогает следователям агрегировать и визуализировать утечки данных, такие как адреса электронной почты, пароли и другую личную информацию, найденную на форумах в темной паутине или на подпольных рынках.

С помощью этих инструментов аналитики, занимающиеся разведкой угроз, могут выстраивать взаимосвязи, отслеживать цифровые личности и соотносить данные по нескольким утечкам, чтобы лучше понять поведение и сети субъектов угроз.



RaidForums Omnipotent → BreachForums Pompompurin → BreachForums Baphomet

Поиск киберпреступника: IntelX

• Intelligence X (IntelX) — это поисковая система и архив, которая собирала огромные объемы данных из интернета, даркнета, а также публичные утечки информации. IntelX индексировал и делал доступными базы данных, которые хакеры продавали или распространяли на закрытых форумах. Члены подпольных сообществ возмутились тем, что сервис «крадет» их эксклюзивный контент и делает его доступным для всех (включая правоохранительные органы) бесплатно или по подписке.

В ответ на это члены форумов организовали доксинг против Кляйснера (основателя IntelX), распространяя его личную информацию, такую как адрес и телефонные номера, с целью запугивания и дискредитации.

1. Корреляция данных: Методы сопоставления собранных данных для выявления закономерностей и связей между участниками и событиями.

2. Анализ настроений: Использование технологий обработки естественного языка (NLP) для оценки общественных настроений и реакции на события.

3. Анализ сетей: Составление карт взаимосвязей участников на основе данных для выявления криминальных сетей.



Полная статья со всей хронологией событий

Intelligence X продолжает работать и сегодня, оставаясь одним из самых известных и крупных легальных архивов утечек данных для ИБ-специалистов. Киберпреступникам не удалось уничтожить сервис, а сам Кляйснер стал еще более медийной фигурой в сфере кибербезопасности.

БЛОК 4

Защита личных данных

Цифровой след, пароли и 2FA, покупки, ИИ-сервисы, взлом аккаунта

Соцсети: три случая, которые стоит разобрать

Пермь, 2015

Ранним утром 22 августа неизвестный напал на женщину и похитил её вещи. Затем он поставил «лайк» под её фото во «ВКонтакте». Эта отметка помогла быстро установить его личность: задержан через восемь дней, при задержании оказывал сопротивление. Источник не сообщает, как именно отслеживался профиль жертвы, поэтому слежку здесь утверждать нельзя.

Мумбаи, 2019

8 декабря 2019 года 22-летний мужчина выложил в Instagram селфи с геоотметкой у ресторана. Четверо мужчин пришли туда, представились его поклонниками, увезли его и напали; похитители использовали его банковскую карту. Все четверо задержаны в тот же день: трое взрослых и один несовершеннолетний.

Мэриленд, США

Бывший партнёр следил за новым парнем бывшей через функцию геопозиции в Instagram и заходил в её аккаунт с собственного телефона: она однажды входила в профиль с его устройства. Итог: убийство, приговор — 30 лет. Адвокат назвал это самообороной и обещает апелляцию.

Геоотметки, публичные фото и общие устройства дают злоумышленнику адрес и доступ к аккаунту

Онлайн-покупки: проверка сайта и утечки

Как мошенник находит данные, как OSINT помогает заподозрить фейковый сайт и чем обернётся утечка

1. Как мошенник получает данные через OSINT

• Публичные профили, посты о покупках и старые утечки дают имя, телефон, почту и магазин.

• С этим набором пишут письмо или звонят «из банка» и просят подтвердить карту или код из SMS.

• Карта редко лежит в открытом доступе, но контакты и заказы делают обман убедительным.

2. Как OSINT помогает распознать фейковый сервис

• Дата регистрации домена (WHOIS): сайт, созданный недавно, — повод насторожиться.

• Адрес, реквизиты и домен сверяются с официальным сайтом бренда и открытыми реестрами.

• Название магазина + «мошенники», «отзывы» — часто сразу видно предупреждения.

3. Активный OSINT: дропперы

• Дропперы (мулы) — люди, которые переводят или обналичивают чужие деньги за вознаграждение. Через них выводятся средства мошенников.

• Их выявляют по связям счетов и переводов и по объявлениям о «лёгком заработке».

• Это активная разведка: часть шагов требует взаимодействия с объектом — здесь проходит граница с законом и социальной инженерией.



Пароли и двухфакторная аутентификация

Длинная фраза	От 12–16 символов лучше короткого «сложного» пароля
Уникальный пароль	Для каждого сервиса свой. Менеджер паролей поможет его хранить
2FA	Даже с украденным паролем вход требует второго фактора
Приложение	Аутентификатор надежнее SMS: SMS можно перехватить через подмену SIM-карты
Коды из SMS	Никому не сообщайте. Сотрудники банка и техподдержки их не спрашивают

Самая частая причина взлома: повторное использование пароля после утечки на другом сервисе.

ИИ-сервисы: что не вводить в чат

Персональные данные ФИО, паспорт, адрес, данные детей и близких

Коммерческая тайна договоры, внутренние документы, исходный код компании

Пароли и коды никогда не просите ИИ «проверить» пароль или код из SMS

Чувствительное медицинские, банковские и юридические подробности о себе

Настройки проверяйте, использует ли сервис ваши диалоги для обучения, и отключайте историю, если можно

Если аккаунт взломали: что делать

1. Смена пароля	Меняйте пароль с устройства, которому доверяете
2. Сессии	Завершите все активные сессии и отвяжите неизвестные устройства
3. Восстановление	Проверьте почту и телефон восстановления. Их могли подменить
4. Почта и приложения	Проверьте пересылку писем, фильтры и подключенные сервисы
5. Контакты	Предупредите знакомых: с аккаунта могут рассылать фишинг
6. Деньги	Если списали средства, сразу звоните в банк и подайте заявление в полицию

БЛОК 5

Право, этика и вопросы

Где проходит граница законного сбора данных

Право и этика: где граница

Неправомерный доступ

Вход в чужую систему с украденными данными: ст. 272 УК РФ (Неправомерный доступ к компьютерной информации - от штрафов и исправительных работ до 7 лет лишения свободы)

Частная жизнь

Сбор и распространение сведений о частной жизни: ст. 137 УК РФ (Нарушение неприкосновенности частной жизни - от штрафов и исправительных работ до 5 лет лишения свободы)

Доксинг

Сбор и публикация личных данных человека может нанести реальный вред (ст. 137, 272, 163, 128.1 УК РФ, административная, гражданская ответственность)

Правило

Собирайте данные только законными способами и только то, на что есть основание

Общая информация, не юридическая консультация. Квалификация зависит от обстоятельств.

Вопросы для обсуждения

Вопрос 1	Мошенник звонит «из банка», называет ваши ФИО и последнюю операцию. Из каких источников он мог это взять и что проверите в первую минуту?
Вопрос 2	Коллега просит пароль от общего рабочего аккаунта «срочно, для клиента». Почему это опасно, даже если просьба похожа на рабочую?
Вопрос 3	Компания запускает программу «цифрового следа» для сотрудников: проверка соцсетей, открытых данных. Где граница между защитой компании и контролем личной жизни?

Источники данных

Positive Technologies. CODE RED 2026: Актуальные киберугрозы для российских организаций (2025) — ptsecurity.com/research/analytics/russia-cyberthreat-landscape-2026

Positive Technologies. Тренды атак в 2026 году — ptsecurity.com/research/analytics/trendy-atak-v-2026-godu

Positive Technologies. Актуальные киберугрозы для организаций в СНГ: H2 2024 – Q3 2025 — ptsecurity.com/research/analytics/cis-cyberthreat-landscape-h2-2024-q3-2025

Positive Technologies. Анатомия цифровых бурь (трендовые уязвимости 2025) — ptsecurity.com/research/analytics/the-anatomy-of-digital-storms

Positive Technologies. Актуальные киберугрозы: IV квартал 2024 года (данные по частным лицам) — по публикации CNews, 20.03.2025



90 процентов разведданных приходит из открытых источников и только 10 — за счёт работы агентуры

— генерал-лейтенант Самуэль Уилсон,
руководитель Разведывательного управления
Министерства обороны США